TITAI V11

Full-Spectrum Adversarial Engineering Report

Architecture, durability, security, governed intelligence, product design, testing, evidence, and release integrity in one repository-grounded mission.

RELEASE CLASSIFICATION **DEVELOPMENT ONLY**

AUDIT DATE	11 July 2026
SAFE VALIDATION	31 files / 113 tests passed
FOCUSED V11 SUITE	8 files / 32 tests passed
STATIC ROAST	33 of 34 controls passed
DURABLE PROOF	Injected crash / 2 attempts / 1 side effect
NATIVE INTEGRATION	Blocked before collection: missing better_sqlite3.node

This report distinguishes verified behavior, implemented code, partial controls, environment blockers, and unstarted work. No roadmap item is represented as completed evidence.

1. Executive summary

v11 converts several v10 architectural intentions into active code: explainable model routing, governed-memory prompt assembly, versioned tool capability enforcement, bounded tool runtime, artifact idempotency, a controlled durable envelope, a serializable approval-wait contract, and two evidence-first operator surfaces.

The result is materially stronger but remains a development release because granular durable resume, native database tests, full build, browser E2E, accessibility, and independent release verification are not proven.

- 31 safe test files passed with 113 tests; the focused v11 suite contributes 32 tests.
- Baseline evaluation passed 8 of 8 cases.
- Durable crash proof passed with two attempts and exactly one side effect.
- Static Roast passed 33 of 34 controls.
- Three native SQLite suites failed before test collection because the binding file is absent.
- The production build did not finish inside a bounded 240-second window and is not claimed as passing.
- The new run dossier and operations signal plane are implemented and type-checked, but browser and accessibility verification remain blocked.

2. Verified starting condition

The input was the English-only v10 hardening package. Its canonical, language, source-lint, TypeScript, migration, release-audit, and Roast validation gates passed. The existing architecture contained a process-local runner, a portable durable core, SQLite durability tables, governed-memory storage, application backup, an evidence ledger, SBOM and provenance generation, and a 50-finding Roast register.

3. Implemented architecture changes

Measured model routing

A persistent model profile registry records capability, reliability, latency, cost, energy, privacy, sovereignty, evaluation confidence, license, and artifact hash. Routing applies hard constraints before deterministic utility scoring. No eligible model is an explicit failure state, and the selected and fallback routes are stored on the run.

Governed memory prompt boundary

Prompt assembly retrieves only active user-owned memory, applies a token budget, quarantines instruction-like, restricted, highly contradictory, or low-authority procedural records, and labels selected records as untrusted evidence that cannot override policy or tool authority.

Tool capability and runtime boundary

Each tool declares schema version, risk, effect, idempotency strategy, network and filesystem needs, timeout, and maximum output size. The runner enforces the agent allowlist, bounded execution, output ceilings, and deterministic artifact idempotency.

Controlled durable cutover

Five runner modes are defined. Durable execution is restricted to simulation or dry-run and wraps the current run in a durable single-step envelope. Shadow mode records comparison state without duplicating side effects. This is deliberately partial and reversible.

Approval continuation primitive

A serializable revision-checked approval state machine proves one terminal decision, stale-write rejection, expiry, and serialization. It is not yet persisted or wired to active resume.

Operator evidence surfaces

The run dossier exposes execution mode, route rationale, memory selection, human authority, tool effects, and recovery evidence. The operations signal plane exposes SLO posture, approval waits, durable state, and outbox pressure while warning against interpreting zero observations as production health.

4. Adversarial engineering evidence

Generated tests reject directed cycles from size 2 through 25, accept acyclic plans independent of input order, prove model-route determinism under candidate permutation, fail closed when all candidates violate hard constraints, and reject sampled illegal run, step, and approval transitions. Tool tests prove output overflow and timeout failure. Memory tests prove quarantine behavior. Approval tests prove revision and terminal-state invariants.

5. Product and design outcome

Seven structurally different directions were evaluated. The selected Evidence Control Plane combines an evidence-first run dossier with a linear operations signal plane. It avoids a generic card grid, uses text, icon, border, and color redundancy, supports narrow widths and reduced motion, and never describes structural evidence as semantic correctness.

Direction	Strength	Risk	Decision
Operational command map	Fast incidents	Graph overload	Rejected default
Evidence-first dossier	Audit comprehension	Density	Selected
Temporal execution timeline	Replay	Weak portfolio view	Secondary
Dependency graph workspace	Planning	Mobile and a11y	Specialist
Multi-pane cockpit	Operator throughput	Generic enterprise feel	Rejected thesis
Spatial agent organization	Distinctiveness	Anthropomorphic decoration	Rejected
Canonical documents	Governance	Weak live operations	Retained

6. Validation results

Gate	Result	Evidence / limitation
Canonical validation	**PASS**	57 tasks, 58 claims, 28 sources, 23 ADRs
English-only validation	**PASS**	No unintended non-Latin writing-system content
Source lint	**PASS**	Non-interactive source hygiene and boundary checks
TypeScript	**PASS**	tsc --noEmit
Migration validator	**PASS**	6 files; 12 required tables; no native driver loaded
Safe tests	**PASS**	31 files; 113 tests
Focused v11 tests	**PASS**	8 files; 32 tests
Baseline evaluation	**PASS**	8 / 8 cases
Durable crash proof	**PASS**	2 attempts; 1 side effect; encrypted restore evidence
Static Roast	**PARTIAL**	33 / 34; Drizzle baseline remains open
Native SQLite suites	**BLOCKED**	Missing better_sqlite3.node; zero tests collected
Production build	**BLOCKED**	Bounded timeout during optimized build
Browser E2E	**BLOCKED**	Application build and native runtime unavailable
Accessibility / visual regression	**BLOCKED**	Browser execution unavailable

7. Security and sovereignty findings

- Memory and fetched content are explicitly untrusted; they cannot grant authority.
- Tool authority derives from authenticated ownership, allowlist, policy, capability, and approval rather than prompt text.
- Local simulation and Ollama-compatible paths preserve no-commercial-key operation.
- No hosted font, remote analytics, or mandatory cloud service was introduced.
- Tools still execute in the trusted application process; no OS-level sandbox was added.
- The dependency advisory for Drizzle remains open because a real verified upgrade was not available in this environment.

8. Performance, cost, and energy

The repository records token budgets, run latency percentiles, queue-related durable status, and model profile fields for latency, cost, and energy. No production workload, wall-power measurement, or statistically meaningful load campaign was available; therefore v11 makes no optimization or break-even claim. The bounded test groups complete in roughly five to six seconds each in this environment, while the production build exceeded 240 seconds.

9. Remaining production blockers

- Granular durable checkpoints and worker fencing in the active runner.
- Persisted approval waits connected to restart-safe continuation.
- Transactional binding of external side-effect receipt, event, audit, checkpoint, and outbox.
- Native SQLite migration, race, audit, approval-expiry, and runner integration tests.
- Complete tenant, workspace, and service-identity model.
- Repeatable model benchmarks that populate profile confidence and freshness.
- Full Next.js build, Playwright E2E, accessibility automation, and visual regression.
- Independent verifier bound to final source, test, artifact, and archive hashes.

10. Full Roast finding register

The following 50 findings are the authoritative project-risk register. A fixed status means the narrow original finding is addressed and has repository evidence; it does not imply the entire domain is complete.

F-001 - Detached in-memory execution cannot survive process loss

SEVERITY	STATUS	CONFIDENCE	CATEGORY
CRITICAL	partially_mitigated	high	durability

A feature-flagged durable envelope and SQLite durable primitives now exist, but granular step resume and active restart recovery remain incomplete.

Impact: Long-running or side-effecting jobs can disappear, duplicate, or remain permanently inconsistent after deployment, crash, or upgrade.

Evidence: src/lib/engine/start.ts, src/lib/engine/runner.ts, src/lib/db/schema.ts

Recommendation: Complete native multi-process crash tests and replace the single-step envelope with granular checkpoints and fencing.

Acceptance test: Kill the worker at every checkpoint boundary and prove the run resumes exactly once with preserved ownership and evidence.

F-002 - Side effects lack persisted idempotency and atomic evidence

SEVERITY	STATUS	CONFIDENCE	CATEGORY
CRITICAL	partially_mitigated	high	durability

The v9 portable core now persists deterministic side-effect receipts and proves crash replay without duplication. The production runner still lacks the SQLite transactional receipt, event, and audit integration.

Impact: A crash after a side effect but before acknowledgement can repeat irreversible work or create evidence that disagrees with reality.

Evidence: src/lib/engine/runner.ts, src/lib/engine/events.ts, src/lib/engine/audit.ts, src/lib/db/schema.ts, src/lib/durable/engine.ts, docs/canonical/evidence/durable-vertical-slice.json

Recommendation: Migrate the production runner to the portable contract with a SQLite compare-and-set lease and transactional outbox.

Acceptance test: Inject a crash after external success but before event commit and prove the retry does not repeat the effect.

F-003 - Deployment model conflicts with globally shared mutable data

SEVERITY	STATUS	CONFIDENCE	CATEGORY
CRITICAL	partially_mitigated	high	identity-tenancy

Authentication is multi-user, but policies, templates, and parts of audit/configuration are global rather than tenant-owned. Administrative restrictions reduce some exposure but do not establish a complete tenancy model.

Impact: One user can be affected by another user's global configuration or data; future multi-user deployment risks cross-tenant leakage and confused authority.

Evidence: src/lib/db/schema.ts, src/app/api/policies/route.ts, src/app/api/templates/route.ts, src/app/api/audit/verify/route.ts

Recommendation: Choose and enforce either explicit single-owner mode or workspace/tenant ownership across every mutable record and query.

Acceptance test: Create two tenants and prove every read, write, audit, template, skill, run, and artifact is isolated under adversarial identifiers.

F-004 - HTTP and provider endpoints allowed server-side request forgery

SEVERITY	STATUS	CONFIDENCE	CATEGORY
CRITICAL	fixed_in_v8	high	security-egress

User-influenced HTTP and provider base URLs previously had no private-network, loopback, metadata, DNS-rebinding, or redirect boundary.

Impact: An agent could probe internal services, cloud metadata, or local control planes.

Evidence: src/lib/security/egress.ts, src/lib/engine/tools/httpFetch.ts, src/lib/engine/gateway.ts, tests/egress.test.ts

Recommendation: Keep destination and redirect validation, DNS resolution checks, and explicit local-model exceptions under policy.

Acceptance test: Run the egress suite against loopback, RFC1918, link-local, metadata, IPv6, encoded addresses, mixed DNS answers, and redirect chains.

F-005 - Invalid or cyclic plans could be reported as completed

SEVERITY	STATUS	CONFIDENCE	CATEGORY
CRITICAL	fixed_in_v8	high	runtime-correctness

The original scheduler could reach no-ready-step state while unfinished nodes remained and still finish the run successfully.

Impact: A structurally impossible plan could produce a false success signal and misleading evidence.

Evidence: src/lib/engine/plan.ts, src/lib/engine/runner.ts, tests/plan.test.ts

Recommendation: Retain preflight plan validation and fail closed when unfinished work has no executable node.

Acceptance test: Test duplicate nodes, unknown edges, self-dependencies, cycles, excessive steps, and runtime deadlock.

F-006 - No tested sovereign backup and restore path

SEVERITY	STATUS	CONFIDENCE	CATEGORY
CRITICAL	fixed_in_v10	high	recovery

The v10 package creates a consistent SQLite snapshot, encrypts it with scrypt and AES-256-GCM, verifies integrity and required tables, restores atomically, preserves an overwritten database, and includes positive and negative restore tests.

Impact: Loss or corruption of the SQLite database, keys, artifacts, or model configuration can be unrecoverable.

Evidence: docs/canonical/20_DATA_LIFECYCLE_CONTRACT.md, docs/canonical/24_HONEST_LIMITATIONS.md, src/lib/durable/backup.ts, docs/canonical/evidence/durable-vertical-slice.json, src/lib/backup/application-backup.ts, scripts/backup-application.mjs, scripts/restore-application.mjs, tests/application-backup.test.ts, docs/canonical/decisions/ADR-0023-encrypted-application-database-backup.md

Recommendation: Run periodic clean-deployment RTO/RPO drills and store the passphrase separately from the backup.

Acceptance test: Restore the encrypted backup into a clean target, verify the sentinel data and database checks, then prove wrong-key, tamper, and unauthorized-overwrite attempts fail closed.

F-007 - Drizzle ORM remains on a version with a high-severity advisory

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	open	high	supply-chain

The current dependency range resolves below the audited fixed line identified by npm audit for identifier-related SQL injection.

Impact: Unsafe identifier construction in affected paths can turn application input into SQL structure rather than data.

Evidence: package.json, docs/roast/evidence/npm-audit.json

Recommendation: Upgrade Drizzle ORM to a supported non-vulnerable release, regenerate/migrate safely, and execute database integration tests.

Acceptance test: npm audit contains no high advisory for Drizzle and all migration/query/integration tests pass on a clean install.

F-008 - Any authenticated user could mutate global policy

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	fixed_in_v8	high	authorization

The policy update path previously had an ineffective administrative check while changing system-wide policy.

Impact: A normal user could weaken approval requirements for all users.

Evidence: src/app/api/policies/route.ts

Recommendation: Retain explicit administrative authorization and later tenant-scope policy records.

Acceptance test: A non-admin receives a denial and cannot change persisted policy; an authorized admin creates an attributable audit event.

F-009 - Skill identifiers enabled cross-user prompt access or attachment

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	fixed_in_v8	high	authorization

Direct skill fetch and agent skill replacement did not consistently verify ownership.

Impact: A user who guessed an identifier could read or attach another user's procedural prompt material.

Evidence: src/app/api/skills/[skillId]/route.ts, src/app/api/agents/[agentId]/route.ts

Recommendation: Keep owner/built-in checks on both reads and relationship writes.

Acceptance test: Attempt direct reads and attachment with another user's skill identifier and prove denial without existence leakage.

F-010 - New or empty agents inherited every tool

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	fixed_in_v8	high	capability-security

Agent creation and runtime fallback could translate absent or empty tool configuration into the full registry.

Impact: A minimally configured agent could unexpectedly gain network or write authority.

Evidence: src/lib/engine/tools/index.ts, src/app/api/agents/route.ts, src/lib/engine/start.ts

Recommendation: Keep an explicit low-risk default allowlist and treat an empty list as no capabilities.

Acceptance test: Create agents with omitted and empty tool lists; prove only documented tools can execute.

F-011 - Catch-all policy allowed medium-risk actions automatically

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	fixed_in_v8	high	human-oversight

The default policy set included a broad catch-all automatic path that weakened the documented fallback behavior.

Impact: Risky actions could bypass human review despite the UI implying otherwise.

Evidence: src/lib/engine/policy.ts, tests/policy.test.ts

Recommendation: Keep fail-closed fallback policy and require explicit, narrow auto-approval rules.

Acceptance test: Unknown and medium/high-risk actions resolve to human review or denial in policy tests.

F-012 - Runs and approvals have no complete wall-clock deadline model

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	partially_mitigated	high	reliability

Runs now accept explicit wall-clock deadlines and output/context budgets; approvals persist an expiry timestamp and are expired by local timers and boot recovery. A durable timer service and restart-safe continuation are still absent.

Impact: A run can occupy resources indefinitely or remain pending forever after user abandonment.

Evidence: src/lib/engine/runner.ts, src/app/api/approvals/[approvalId]/route.ts, src/lib/db/schema.ts, src/app/api/runs/route.ts, src/lib/db/index.ts, drizzle/0001_v10_hardening.sql

Recommendation: Add persisted deadlines, timeout ownership, cancellation propagation, and deterministic terminal states.

Acceptance test: Advance a fake clock across model, tool, approval, and run deadlines and prove exact terminal events and released leases.

F-013 - Run event sequence allocation is race-prone

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	partially_mitigated	high	integrity

Run event sequence allocation and insertion now execute under BEGIN IMMEDIATE with a unique run/sequence constraint and an atomic outbox record. Native multi-process contention tests remain blocked in this environment.

Impact: Concurrent writers can duplicate or reorder sequence numbers and break replay evidence.

Evidence: src/lib/engine/events.ts, src/lib/db/schema.ts, drizzle/0001_v10_hardening.sql, scripts/validate-migrations.mjs

Recommendation: Use a transactionally allocated sequence or append-only event table with a unique run/sequence constraint and retry.

Acceptance test: Run concurrent appenders and prove contiguous unique ordering under load and injected transaction retries.

F-014 - Audit hash-chain append is race-prone and not externally anchored

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	partially_mitigated	high	audit-integrity

Audit hash-chain read, hash calculation, append, and outbox insertion now run in one immediate transaction. External anchoring and native concurrent-writer tests remain.

Impact: Concurrent events can fork the chain; a database administrator can rewrite the entire chain and recompute hashes.

Evidence: src/lib/engine/audit.ts, scripts/verify-audit.ts, src/lib/db/schema.ts, drizzle/0001_v10_hardening.sql

Recommendation: Serialize append, add uniqueness, sign periodic roots, and optionally export roots to independent storage.

Acceptance test: Generate concurrent audit writes, verify one linear chain, then mutate history and prove signed-root verification fails.

F-015 - Disabled provider configurations were still eligible

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	fixed_in_v8	high	provider-routing

Provider activation status was not consistently enforced during dispatch or provider tests.

Impact: An operator could believe a provider was disabled while the system still sent data to it.

Evidence: src/lib/engine/gateway.ts, src/lib/engine/runner.ts, src/app/api/providers/test/route.ts

Recommendation: Retain enabled checks at every provider resolution boundary.

Acceptance test: Disable each provider and prove dispatch, health test, and fallback routing never contact it.

F-016 - Database migration failure was tolerated

SEVERITY	STATUS	CONFIDENCE	CATEGORY

HIGH	fixed_in_v8	high	startup-integrity

Migration errors were logged but startup could continue against an unknown schema.

Impact: The application could write incompatible data or fail later in less diagnosable ways.

Evidence: src/lib/db/index.ts

Recommendation: Keep startup fail-closed for required schema migrations.

Acceptance test: Force a migration failure and prove the process refuses readiness without serving mutation routes.

F-017 - Fetched content remains a prompt-injection channel

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	partially_mitigated	high	agent-security

Fetched data is now labeled untrusted and egress-limited, but untrusted text still enters model context without a fully enforced authority separation or content transformation policy.

Impact: A malicious page can attempt to override instructions, induce tool use, or exfiltrate context.

Evidence: src/lib/engine/tools/httpFetch.ts, src/lib/engine/runner.ts, docs/canonical/07_SECURITY_TRUST_SAFETY.md

Recommendation: Separate data from instructions, apply trust labels in the internal protocol, and require policy authorization independent of model text.

Acceptance test: Use adversarial fetched pages that request secrets and destructive tools; prove zero authority escalation and no protected-context leakage.

F-018 - Native database integration tests cannot run in the constrained environment

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	environment_blocked	high	verification

The safe install deliberately skips native post-install scripts, leaving better-sqlite3 unavailable for three database-backed suites.

Impact: Critical approval expiry, audit, and runner integration behavior is not independently executed in this environment.

Evidence: docs/roast/evidence/v8-full-tests.txt, docs/canonical/24_HONEST_LIMITATIONS.md

Recommendation: Run the blocked suites on an approved clean Linux CI image with pinned Node headers and a trusted prebuilt/native toolchain.

Acceptance test: All database suites pass from a clean lockfile install and publish logs, environment digest, and database reset evidence.

F-019 - Production build did not complete end-to-end in the audit environment

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	environment_blocked	high	release-verification

The production build compiles and completes type validation, but page-data collection cannot load the absent better-sqlite3 native binding in the constrained environment.

Impact: A source-level and compile-level green result does not prove deployable application startup or route data collection.

Evidence: docs/canonical/evidence/v10-build.txt, scripts/build-production.mjs

Recommendation: Run the build with the verified native binding on a trusted CI or development host, then execute startup and browser E2E gates.

Acceptance test: A clean install completes the production build, starts the server, and passes Playwright without hidden network or native-binding errors.

F-020 - User data export, correction, and deletion are not implemented end-to-end

SEVERITY	STATUS	CONFIDENCE	CATEGORY

HIGH	partially_mitigated	high	data-governance

User export, password-confirmed deletion, owned-data cascade, governed-memory correction/deletion, and logical audit redaction overlays are implemented. Native end-to-end deletion, backup propagation, and legal retention validation remain.

Impact: Users cannot exercise data rights reliably and deleted data may survive in logs, artifacts, or backups.

Evidence: docs/canonical/20_DATA_LIFECYCLE_CONTRACT.md, src/lib/db/schema.ts, src/app/api/account/export/route.ts, src/app/api/account/delete/route.ts, src/app/api/memory/route.ts, src/lib/engine/audit.ts, docs/canonical/data/DATA_INVENTORY.json

Recommendation: Implement data inventory-backed export and deletion workflows with tombstone/backup semantics and audit evidence.

Acceptance test: Create a user with all data classes, export it, delete it, search every primary/derived store, restore an older backup, and prove policy-compliant handling.

F-021 - Custom templates are globally visible and mutable

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	fixed_in_v10	high	identity-tenancy

Custom templates now carry an owner identifier; listing and creation expose only built-in templates plus the authenticated user's templates.

Impact: Private workflows or proprietary prompts can be exposed or changed across users.

Evidence: src/lib/db/schema.ts, src/app/api/templates/route.ts, drizzle/0001_v10_hardening.sql

Recommendation: Separate immutable built-ins from tenant-owned custom templates and scope every query.

Acceptance test: Two-user route tests prove private templates cannot be listed, read, updated, or referenced cross-tenant.

F-022 - Audit access is restricted but audit data remains globally modeled

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	partially_mitigated	high	identity-tenancy

The route now restricts entries to administrators, but audit rows lack a complete tenant/workspace ownership model and delegated audit roles.

Impact: A global administrator becomes a high-value data aggregation point and tenant-level audit cannot be safely delegated.

Evidence: src/app/api/audit/verify/route.ts, src/lib/db/schema.ts

Recommendation: Add tenant/workspace dimensions and explicit audit-reader roles while preserving system-level security audit separation.

Acceptance test: Tenant auditors see only their workspace; system auditors see redacted cross-tenant metadata under separate authorization.

F-023 - Registration remains open with weak abuse controls

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	fixed_in_v10	high	authentication

Registration now bootstraps only the first administrator by default, remains closed afterward unless explicitly enabled, supports an invite token, enforces a twelve-character minimum, and uses rate limiting without trusting proxy headers by default.

Impact: An exposed installation can be populated by unauthorized users and amplified against local or paid model resources.

Evidence: src/app/api/register/route.ts, src/lib/auth/password.ts, src/lib/rate-limit.ts, .env.example

Recommendation: Add explicit registration mode, invitation/first-owner bootstrap, stronger password checks, throttling, and non-enumerating responses.

Acceptance test: Unauthenticated registration is denied in closed mode; invite reuse, enumeration, weak passwords, and burst attempts fail safely.

F-024 - Secret encryption lacks documented rotation and context binding

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	partially_mitigated	medium	cryptography

Provider secrets now use versioned AES-GCM records, HKDF purpose separation, and user/provider context binding with legacy decryption compatibility. Automated rotation, revocation, and custody recovery are not complete.

Impact: A leaked master key or ciphertext relocation can expose all provider credentials with limited recovery options.

Evidence: src/lib/crypto.ts, docs/canonical/07_SECURITY_TRUST_SAFETY.md, src/app/api/providers/route.ts, src/lib/engine/runner.ts, tests/crypto.test.ts

Recommendation: Introduce key IDs, rotation, AEAD associated data, scoped decrypt authority, secure backup handling, and revocation drills.

Acceptance test: Rotate from key A to B without downtime, prove old ciphertext migration, reject swapped record context, and restore credentials securely.

F-025 - Run creation has no client idempotency contract

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	partially_mitigated	high	api-reliability

Run creation accepts a user-scoped Idempotency-Key, serializes create-or-reuse under BEGIN IMMEDIATE, rejects key reuse with a different request, and has a unique database constraint. Native concurrent API tests remain blocked.

Impact: Network retries or double clicks can duplicate expensive or destructive work.

Evidence: src/app/api/runs/route.ts, src/lib/db/schema.ts, src/lib/engine/runner.ts, drizzle/0001_v10_hardening.sql

Recommendation: Accept scoped idempotency keys, persist request/result hashes, and return the original run for safe retries.

Acceptance test: Send the same request concurrently and repeatedly; prove exactly one run and a deterministic replay response.

F-026 - Approval expiry is not owned by a durable timer

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	partially_mitigated	high	human-oversight

Approval expiry is persisted and enforced by local wait timers and startup sweeping, but no independent durable timer worker owns expiry while the application is offline.

Impact: Expired approvals can remain pending or resume ambiguously, blocking work and weakening policy guarantees.

Evidence: src/lib/engine/runner.ts, src/app/api/approvals/[approvalId]/route.ts, tests/approval-expiry.test.ts, src/lib/db/index.ts, src/lib/db/schema.ts

Recommendation: Persist approval deadlines and let a durable worker own expiry, cancellation, and notification.

Acceptance test: Restart before and after expiry and prove one deterministic expired transition and no later execution.

F-027 - Restart semantics for pending approvals are incomplete

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	partially_mitigated	high	recovery

A serializable revision-checked approval wait contract now proves one-decision and expiry semantics, but the active runner still cannot resume it after restart.

Impact: An approved action may never resume or may be reissued incorrectly after restart.

Evidence: src/lib/engine/runner.ts, src/lib/db/schema.ts, src/lib/durable/approval-continuation.ts, tests/approval-continuation.test.ts

Recommendation: Persist the wait contract, durable timer, continuation pointer, and requeue behavior in the active runner.

Acceptance test: Restart with a pending approval, decide it from another process, and prove the exact continuation resumes once.

F-028 - Configured maximum plan size was not enforced

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	fixed_in_v8	high	resource-governance

The planner schema previously accepted plans beyond the configured step limit.

Impact: A model could create runaway work graphs and consume disproportionate resources.

Evidence: src/lib/engine/plan.ts, tests/plan.test.ts

Recommendation: Keep max-step enforcement at parse/validation time.

Acceptance test: Generate plans at limit, limit+1, and extreme sizes; prove bounded parse time and clear rejection.

F-029 - Tool iteration exhaustion could be treated as success

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	fixed_in_v8	high	runtime-correctness

A step could leave the model still requesting tools after the loop budget but continue toward completion.

Impact: Incomplete or looping work could be presented as successful.

Evidence: src/lib/engine/runner.ts

Recommendation: Fail the step and run with explicit budget-exhausted evidence.

Acceptance test: Use a model fixture that always requests another tool and prove deterministic failure at the configured limit.

F-030 - Usage accounting could double-count tokens

SEVERITY	STATUS	CONFIDENCE	CATEGORY
MEDIUM	fixed_in_v8	high	economics

Token usage could be recorded both through provider events and response usage aggregation.

Impact: Cost, capacity, and model-routing decisions could be based on inflated telemetry.

Evidence: src/lib/engine/runner.ts, src/lib/engine/event-types.ts

Recommendation: Use one authoritative accounting path with reconciliation fields.

Acceptance test: Replay a response with provider usage events and summary usage; prove totals equal the provider bill once.

F-031 - Rejected approval did not close the tool evidence chain

SEVERITY	STATUS	CONFIDENCE	CATEGORY
MEDIUM	fixed_in_v8	high	evidence-integrity

A rejected action produced a model-facing result but no matching tool.result event.

Impact: Evidence reconstruction reported an unmatched call and could not explain the human decision path.

Evidence: src/lib/engine/runner.ts, src/lib/engine/evidence-summary.ts

Recommendation: Emit a terminal tool result representing rejection without executing the tool.

Acceptance test: Reject an approval and prove call/result pairing, no side effect, and visible human-decision evidence.

F-032 - Prompts and objectives are duplicated into persistent evidence without minimization

SEVERITY	STATUS	CONFIDENCE	CATEGORY
MEDIUM	partially_mitigated	high	privacy

Full system prompts and run objectives are no longer duplicated into run-start events or audit payloads; hashes and character counts are stored instead. The objective remains once in the run record because it is operational input, and broader retention controls remain.

Impact: Sensitive business data can persist longer and in more stores than users expect.

Evidence: src/lib/engine/runner.ts, src/lib/engine/audit.ts, src/lib/engine/events.ts, src/app/api/account/export/route.ts

Recommendation: Store references/hashes and redacted summaries by default; define an explicit secure evidence retention mode for full content.

Acceptance test: Insert known sensitive markers and prove default logs/events/audit omit them while authorized artifact storage remains traceable.

F-033 - Artifact writes had no practical size ceiling

SEVERITY	STATUS	CONFIDENCE	CATEGORY
MEDIUM	fixed_in_v8	high	resource-governance

The write-artifact tool accepted unbounded content.

Impact: A model could exhaust memory, disk, database capacity, or UI rendering.

Evidence: src/lib/engine/tools/writeArtifact.ts

Recommendation: Keep a documented byte cap and later add streaming/object storage where justified.

Acceptance test: Attempt boundary, boundary+1, and multibyte payloads and prove exact size enforcement.

F-034 - Policy regular expressions can create denial of service

SEVERITY	STATUS	CONFIDENCE	CATEGORY
MEDIUM	fixed_in_v10	medium	policy-engine

Policy patterns pass a bounded safe-regex compiler that rejects oversized expressions, backreferences, lookarounds, nested quantifiers, repeated wildcards, and malformed patterns before evaluation.

Impact: Catastrophic backtracking can block the Node.js event loop during authorization.

Evidence: src/lib/engine/policy.ts, src/app/api/policies/route.ts, src/lib/security/safe-regex.ts, tests/safe-regex.test.ts

Recommendation: Use constrained glob/pattern semantics or safe-regex validation and bounded evaluation.

Acceptance test: Submit known pathological expressions and long inputs; prove bounded latency or rejection.

F-035 - Rate limiting is process-local and trusts client forwarding headers

SEVERITY	STATUS	CONFIDENCE	CATEGORY
MEDIUM	partially_mitigated	high	abuse-control

Forwarding headers are ignored unless proxy trust is explicitly enabled. Rate-limit state remains process-local and therefore is not a distributed production control.

Impact: Attackers can bypass limits across workers/restarts or by rotating forged header values.

Evidence: src/lib/rate-limit.ts, src/app/api/runs/route.ts, src/app/api/providers/test/route.ts, tests/rate-limit.test.ts

Recommendation: Use authenticated principal/workspace keys and a shared limiter or documented single-process boundary; configure trusted proxies explicitly.

Acceptance test: Exercise multiple workers, restarts, spoofed headers, users, and IPs; prove the intended global and per-user budget.

F-036 - Security headers improved but CSP remains absent

SEVERITY	STATUS	CONFIDENCE	CATEGORY
MEDIUM	partially_mitigated	high	browser-security

The application now sends a Content Security Policy and baseline headers. The compatibility policy still permits inline scripts and styles, and browser-level enforcement tests remain.

Impact: A future injection bug has fewer browser-side containment barriers.

Evidence: next.config.ts

Recommendation: Add nonce/hash-based CSP, report-only rollout, and route tests without breaking Next.js runtime behavior.

Acceptance test: Production responses include the approved CSP and Playwright confirms no required script/style violations.

F-037 - Source lint is intentionally shallow and build ignores ESLint

SEVERITY	STATUS	CONFIDENCE	CATEGORY
MEDIUM	partially_mitigated	high	code-quality

Build no longer suppresses ESLint and the non-interactive source lint checks merge markers, dangerous directives, dynamic code execution, malformed JSON, and client/server boundaries. A full semantic ESLint ruleset remains absent.

Impact: Common correctness, React, security, and accessibility defects can pass CI.

Evidence: scripts/lint-source.mjs, next.config.ts, package.json

Recommendation: Adopt a pinned non-interactive ESLint configuration plus targeted security/accessibility rules and keep the fast scanner as an additional gate.

Acceptance test: A clean install runs lint non-interactively; seeded violations fail with stable diagnostics.

F-038 - No generated SBOM, model inventory, or build provenance

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	fixed_in_v10	high	supply-chain

The release pipeline generates a CycloneDX SBOM, license inventory, model inventory, and source-tree build provenance with hashes.

Impact: Operators cannot reliably identify vulnerable components, licenses, models, plugins, or reproduce the artifact.

Evidence: package.json, docs/canonical/14_ACCEPTANCE_GATES.md, scripts/generate-release-evidence.mjs, docs/canonical/evidence/release/SBOM.cyclonedx.json, docs/canonical/evidence/release/LICENSE_INVENTORY.json, docs/canonical/evidence/release/MODEL_INVENTORY.json, docs/canonical/evidence/release/BUILD_PROVENANCE.json

Recommendation: Generate CycloneDX/SPDX, license inventory, model/plugin hashes, and build provenance during release.

Acceptance test: The extracted ZIP contains validated inventories matching the lockfile and shipped artifacts, signed or hashed in the release manifest.

F-039 - Observability lacks traces, SLOs, and capacity evidence

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	partially_mitigated	high	observability

A local metrics endpoint now reports status counts, latency percentiles, token usage, approval expiry, outbox backlog, durable-job state, and SLO evaluations. Cross-boundary traces, energy measurement, historical capacity series, and telemetry retention remain.

Impact: Operators cannot answer why work is slow, expensive, failing, or saturating resources.

Evidence: src/lib/engine/event-types.ts, docs/canonical/09_EVALUATION_OBSERVABILITY.md, src/lib/observability/metrics.ts, src/app/api/metrics/route.ts, tests/metrics.test.ts

Recommendation: Add redacted trace correlation, metrics, usage reconciliation, queue measures, SLOs, and local dashboards.

Acceptance test: A benchmark run yields traceable p50/p95/p99 latency, queue depth, failure classes, token/cost totals, and an SLO verdict.

F-040 - Governed memory architecture is documentation-only

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	fixed_in_v11	high	memory

Governed memory is implemented and integrated into prompt assembly with owner filtering, expiry, token budgets, quarantine, provenance labeling, corrections, and deletion.

Impact: Long-running agents either forget important context or accumulate untrusted, stale, contradictory, or cross-user material.

Evidence: docs/canonical/06_DATA_MEMORY_KNOWLEDGE.md, src/lib/db/schema.ts, src/lib/memory/governed-memory.ts, src/app/api/memory/route.ts, src/components/memory/memory-ledger.tsx, tests/governed-memory.test.ts, docs/canonical/decisions/ADR-0022-governed-local-memory-baseline.md, src/lib/memory/prompt-context.ts, tests/memory-prompt-context.test.ts

Recommendation: Maintain ablation and poisoning evaluations before expanding automatic memory creation.

Acceptance test: Create contradictory, expired, private, corrected, and deleted memories; prove scoring, provenance, isolation, and removal behavior.

F-041 - Provider selection is not a measured capability router

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	fixed_in_v11	high	model-routing

Model capability profiles, hard eligibility constraints, deterministic utility scoring, explicit fallback, no-eligible failure, persistence, API control, and run-level rationale are implemented.

Impact: Critical work can be dispatched by static configuration rather than demonstrated fitness.

Evidence: src/lib/engine/gateway.ts, src/lib/engine/providers, docs/canonical/05_REASONING_AND_INTELLIGENCE.md, src/lib/models/router.ts, src/lib/models/db-routing.ts, tests/model-router.test.ts

Recommendation: Populate profiles through repeatable benchmark runs and invalidate stale evaluations.

Acceptance test: Given constrained tasks and unavailable models, route to the Pareto-eligible candidate or return no-eligible-model without silent downgrade.

F-042 - Test portfolio is too narrow for the threat and failure model

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	partially_mitigated	high	evaluation

The safe portfolio now includes lifecycle, evidence, egress, durable execution, backup/restore, memory, regex, tool-schema, metrics, context-budget, graph, crypto, and policy tests. Native database, browser, accessibility, load, and broad fault-injection suites remain incomplete.

Impact: The system can pass 47 safe tests while remaining unsafe under realistic operation.

Evidence: tests, e2e, docs/canonical/14_ACCEPTANCE_GATES.md, tests/application-backup.test.ts, tests/governed-memory.test.ts, tests/metrics.test.ts, tests/context-budget.test.ts

Recommendation: Build layered adversarial and fault-injection suites tied to every high/critical finding.

Acceptance test: Each high/critical finding has a failing regression before repair and a passing independent verification after repair.

F-043 - End-to-end tests are brittle smoke checks

SEVERITY	STATUS	CONFIDENCE	CATEGORY
MEDIUM	partially_mitigated	high	evaluation

The Playwright suite now uses operator-supplied credentials, semantic readiness conditions, and coverage for run evidence, agent evaluation, and governed-memory lifecycle. Isolated database fixtures, repeated parallel/serial execution, accessibility assertions, and measured flake-rate evidence remain.

Impact: The suite is materially less brittle, but shared-state and unexecuted browser coverage can still conceal authorization, recovery, accessibility, or concurrency regressions.

Evidence: e2e/smoke.spec.ts, playwright.config.ts, .github/workflows/ci.yml

Recommendation: Add per-run isolated databases and users, deterministic fixture teardown, accessibility checks, authorization negatives, restart recovery, and repeated serial/parallel flake measurement.

Acceptance test: Run the E2E suite repeatedly in serial and parallel modes against isolated state, including accessibility, authorization, offline, and recovery cases, with a bounded measured flake rate.

F-044 - Seed workflow is destructive and includes known demo credentials

SEVERITY	STATUS	CONFIDENCE	CATEGORY
MEDIUM	fixed_in_v10	high	operations

The seed refuses to run unless a destructive-seed flag is set, requires an operator-supplied twelve-character demo password, and no longer contains fallback application secrets or prints credentials.

Impact: Running it in the wrong environment can destroy data or create an easily guessed account.

Evidence: scripts/seed.ts, playwright.config.ts, .env.example

Recommendation: Require explicit development/test environment, random ephemeral credentials, targeted fixture cleanup, and destructive confirmation guards.

Acceptance test: Attempt seed in production mode and against a non-empty protected database; prove hard refusal and no mutation.

F-045 - Evidence percentage measures structure, not truth

SEVERITY	STATUS	CONFIDENCE	CATEGORY
MEDIUM	partially_mitigated	high	evidence-quality

The UI originally risked presenting event-shape completeness as overall evidence quality. It is now labeled structural coverage, but semantic correctness and verifier independence remain separate unfinished controls.

Impact: Users can over-trust a complete-looking ledger even when outputs are wrong or self-verified.

Evidence: src/components/runs/evidence-ledger.tsx, src/lib/engine/evidence-summary.ts

Recommendation: Keep structural labeling and add claim-level evidence, verifier identity, reproducibility, contradiction, and semantic evaluation.

Acceptance test: Show a structurally complete but deliberately false run and prove the UI does not label it verified.

F-046 - Most canonical capabilities remain blocked or unimplemented

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	partially_mitigated	high	program-execution

v9 and v10 implement durable contracts, SQLite persistence primitives, transactional outbox, governed memory, encrypted restore, lifecycle controls, observability, data export/deletion, budgets, and release provenance. Production worker cutover, measured routing, delegated identity, and full native/browser verification remain.

Impact: Documentation volume can be mistaken for platform maturity, obscuring the implementation gap.

Evidence: docs/canonical/tasks/TASKS.json, docs/canonical/16_TRACEABILITY_MATRIX.md, docs/canonical/26_V9_DURABLE_ENGINEERING_REPORT.md, src/lib/durable/sqlite-store.ts, src/lib/backup/application-backup.ts, src/lib/memory/governed-memory.ts

Recommendation: Expose implemented-versus-designed status prominently and execute dependency-unblocking vertical slices rather than adding parallel documents.

Acceptance test: A release dashboard derives status from code/test evidence and cannot count designed-only tasks as delivered capability.

F-047 - SQLite and web-process topology limit safe scale and failover

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	partially_mitigated	high	infrastructure

SQLite now has immediate-transaction serialization, persisted durable schemas, a repository-owned adapter, outbox leases, and migration checks. The web process still launches the production runner and there is no tested worker fleet or failover topology.

Impact: Multi-process deployment, failover, concurrent writers, and horizontal scaling can corrupt assumptions or lose work.

Evidence: src/lib/db/index.ts, src/lib/engine/start.ts, docs/canonical/08_INFRASTRUCTURE_SOVEREIGNTY.md, src/lib/durable/sqlite-store.ts, src/lib/durable/outbox.ts, src/lib/engine/runner.ts, scripts/validate-migrations.mjs

Recommendation: Define supported single-node limits, separate durable worker execution, and introduce a tested persistence profile before scaling out.

Acceptance test: Run load and failover tests at documented limits; unsupported topologies must fail configuration validation.

F-048 - No tested Content Security Policy

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	partially_mitigated	high	browser-security

A CSP is configured and scanned, but it retains unsafe-inline compatibility directives and has not passed browser-level nonce, third-party, or violation-report testing.

Impact: Cross-site scripting impact is not meaningfully contained at the browser policy layer.

Evidence: next.config.ts, scripts/roast-project.mjs

Recommendation: Design and roll out report-only then enforced CSP with route-level automated checks.

Acceptance test: All production pages load under enforced CSP with no unauthorized script, style, frame, connect, image, or font source.

F-049 - Tool arguments are not uniformly governed by explicit versioned schemas

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	fixed_in_v11	high	capability-security

Tools declare versioned schemas and capabilities; arguments are validated, allowlists enforced, and execution is bounded by timeout and output size.

Impact: Malformed, oversized, ambiguous, or injected arguments can reach tool implementations inconsistently.

Evidence: src/lib/engine/tools/index.ts, src/lib/engine/types.ts, src/lib/engine/tools/validate.ts, src/lib/engine/runner.ts, tests/tool-arguments.test.ts, src/lib/engine/tool-runtime.ts, tests/tool-runtime.test.ts

Recommendation: Add OS-level isolation for high-risk tools and maintain mutation tests for schema bypass.

Acceptance test: Fuzz every tool with invalid types, extra fields, oversized values, Unicode edge cases, and schema-version mismatch.

F-050 - Context and output budgets are incomplete

SEVERITY	STATUS	CONFIDENCE	CATEGORY
HIGH	partially_mitigated	high	context-engineering

Run requests now bound context and output tokens; context assembly deterministically preserves mandatory messages and recent complete segments under budget. Adaptive stopping, cache isolation, and omission-quality benchmarks remain.

Impact: Long histories or retrieved content can crowd out policy/current facts, increase cost, and degrade correctness.

Evidence: src/lib/engine/runner.ts, docs/canonical/05_REASONING_AND_INTELLIGENCE.md, src/app/api/runs/route.ts, src/lib/engine/context-budget.ts, tests/context-budget.test.ts

Recommendation: Implement mandatory-context reservation, measured selection, output ceilings, and bounded planner/critic/verifier stopping.

Acceptance test: Run adversarial long-context cases and prove mandatory policy/current code facts survive while cost and latency remain within budget.

11. Release decision

DEVELOPMENT ONLY. The package is suitable for controlled engineering and adversarial evaluation. It is not approved for autonomous multi-user production execution. The classification cannot advance until native database, durable restart, approval continuation, browser, accessibility, and independent verification gates pass.

12. Next canonical sequence

- Persist the approval-wait contract and continuation pointer.
- Split the durable envelope into plan-step checkpoints with lease heartbeat and fencing.
- Run multi-process crash and race tests with a verified native SQLite binding in CI.
- Populate model profiles through a reproducible benchmark campaign.
- Run browser E2E, accessibility, visual regression, and long-content stress states.
- Bind an independent verification report to the final release hash.